

Instituto Tecnológico de Costa Rica

Escuela de Ingeniería en Computadores

Atributo Investigación (IN)

Tema 3: Criptografía post-cuántica

Curso: CE-1115 Seguridad de la Información
Integrantes: José Andrés Arroyo Meoño, 2020092059
Daniel Duarte Cordero, 2022012866
Gustavo Gamboa Mora, 2020023596
Kendall Martínez Carvajal, 2020027358
José Andrés Vargas Torres, 2021453583
Grupo: 1
Fecha: 29 de septiembre de 2026

Atributo Investigación (IN)

Definición oficial

Capacidad para conducir investigaciones de problemas complejos por medio de conocimientos y métodos apropiados, incluyendo el diseño de experimentos, análisis e interpretación de datos y síntesis de información para proveer conclusiones válidas.

IN1. Identifica el problema complejo de ingeniería a investigar

Texto literal del indicador

Identifica el problema complejo de ingeniería a investigar.

Respuesta del grupo

El problema complejo investigado es la **migración de la infraestructura de clave pública hacia criptografía poscuántica (PQC)**. RSA, las curvas elípticas y Diffie-Hellman protegen hoy el establecimiento de claves y las firmas de TLS, VPN, certificados y actualizaciones de software. Una computadora cuántica suficientemente grande podría romperlos con el algoritmo de Shor.

- **Por qué importa ahora:** aunque esa computadora todavía no existe, un adversario puede capturar hoy tráfico cifrado y descifrarlo en el futuro (*store now, decrypt later*). Todo dato que deba seguir siendo secreto durante años ya está expuesto.
- **Qué cambió:** en agosto de 2024 el NIST publicó FIPS 203 (ML-KEM), FIPS 204 (ML-DSA) y FIPS 205 (SLH-DSA). Desde 2025 hay despliegues a gran escala. El problema dejó de ser qué algoritmo usar y pasó a ser cómo migrar.
- **Por qué es complejo:** la migración involucra muchos actores (organizaciones, proveedores de software y hardware, autoridades de certificación) y activos (canales TLS e IPsec, PKI, firmware y datos de larga vida). Exige inventariar dónde se usa criptografía vulnerable, priorizar según el riesgo y sustituirla sin romper la interoperabilidad ni la disponibilidad. Además afecta las tres propiedades de la tríada CID.

Evidencia en el informe: Sección I (Introducción) y Sección III (estado del arte, en particular Joseph et al. y CISA, NSA y NIST).

IN2. Diseña una propuesta de investigación

Texto literal del indicador

Diseña una propuesta de investigación.

Respuesta del grupo

Se diseñó una revisión de literatura tipo *summary paper*, documentada en la Sección II del informe.

- **Preguntas guía:** (1) ¿qué riesgos introduce la computación cuántica?, (2) ¿qué soluciones y estándares existen?, (3) ¿qué dificultades técnicas presenta la migración? y (4) ¿qué evidencia existe de adopción actual?

- **Fuentes de búsqueda:** Consensus para literatura académica y búsquedas web para documentos técnicos y casos recientes. Gemini se usó solo para sugerir posibles fuentes; cada sugerencia se verificó en la fuente original.
- **Cadenas de búsqueda:** “post-quantum cryptography” combinada con *review, standardization, migration, implementation, performance, NIST y security*.
- **Criterios de inclusión:** autoría identificable, relación directa con PQC, evidencia verificable y aporte complementario al resto de fuentes. Además, el conjunto debía combinar las tres categorías (académica, técnica y de actualidad) con un mínimo de dos académicas.
- **Criterios de exclusión:** fuentes sin autoría clara, fuentes secundarias cuando existía la primaria y trabajos poco relacionados con las preguntas guía.
- **Alcance:** fuentes recientes en inglés y español, con énfasis en la transición organizacional y técnica, no en el diseño matemático de los algoritmos.
- **Componente experimental:** una demo reproducible con la biblioteca liboqs (Open Quantum Safe) para observar ML-DSA, uno de los estándares revisados.

IN3. Ejecuta la metodología del plan de investigación para la obtención de datos relevantes

Texto literal del indicador

Ejecuta la metodología del plan de investigación para la obtención de datos relevantes.

Respuesta del grupo

El plan se ejecutó en cuatro pasos.

1. **Búsqueda y filtrado (septiembre de 2026).** Se aplicaron las cadenas de búsqueda y se filtró primero por título, resumen, introducción y conclusiones. Luego se leyeron en detalle las fuentes seleccionadas.
2. **Selección de las cinco fuentes principales.**
 - Académicas: Joseph et al. (*Nature*, 2022) y la revisión sistemática de Näther et al. (*IEEE Access*, 2024), basada en 21 trabajos.
 - Técnicas: NIST FIPS 203/204/205 (2024) y la guía *Quantum-Readiness* de CISA, NSA y NIST (2023).
 - De actualidad: el reporte de despliegue de Westerbaan en el blog de Cloudflare (2025).
 - Casos adicionales para el impacto: dos anuncios de Cloudflare de 2026, sobre IPsec poscuántico (30 de abril) y autenticación ML-DSA hacia servidores de origen, que incluye el incidente del 10 de junio (publicado el 29 de julio).
3. **Extracción de datos.** Cada fuente se registró en la matriz de revisión (Tabla I del informe) con referencia, problema, método, datos o entorno, hallazgo principal y limitación, redactados por el grupo y no copiados de los abstracts. Las cifras de adopción se verificaron contra el texto original. Por ejemplo, el 3.7 % de servidores de origen con soporte poscuántico se confirmó en el artículo de Westerbaan.
4. **Demo en Google Colab con liboqs-python.** Se compiló liboqs y se utilizó ML-DSA-65.
 - Se generó un par de claves; la clave pública midió **1952 bytes**.

- Se firmó el mensaje “Transferir 10000 colones a Bob”; la firma midió **3309 bytes**.
- Se verificó la firma: resultó válida.
- Se simuló un atacante que cambia el monto a 90000 sin tocar la firma: la verificación falló.
- Como ejercicio opcional, quedó preparado un intercambio con ML-KEM-768.

La demo usa solo datos ficticios en un entorno propio.

Organización del trabajo: la búsqueda y la redacción se repartieron por secciones del informe. Dos integrantes prepararon la demo. Otro integrante integró el resumen, la introducción, las conclusiones, las diapositivas y este documento.

IN4. Analiza los datos obtenidos en el desarrollo de la investigación

Texto literal del indicador

Analiza los datos obtenidos en el desarrollo de la investigación.

Respuesta del grupo

Las fuentes se analizaron comparándolas entre sí, no una por una (Secciones III y IV del informe), separando lo que afirma la literatura de las inferencias propias del grupo.

- **Comparación.** Las fuentes cubren etapas distintas de una misma transición:
 - preparación estratégica (Joseph et al.; CISA, NSA y NIST);
 - proceso de migración en cuatro fases: diagnóstico, planificación, ejecución y mantenimiento (Näther et al.);
 - especificación de algoritmos (FIPS 203–205);
 - despliegue real (Westerbaan).

Ninguna fuente aislada cubre el problema completo.

- **Contradicciones y tensiones.**
 - Joseph et al. recomiendan la cripto-agilidad, pero Näther et al. muestran que no existe una definición uniforme de ese concepto ni una forma común de implementarlo.
 - Los esquemas híbridos reducen el riesgo de depender solo de algoritmos nuevos, pero conservan una ruta clásica expuesta a ataques de *downgrade* si la negociación no está protegida.
- **Vacíos.** CISA, NSA y NIST describen actividades de preparación, pero no criterios medibles para declarar que una organización está preparada. La evidencia de despliegue proviene de un solo proveedor.
- **Datos de adopción.** La adopción es desigual:
 - más de la mitad del tráfico humano de Cloudflare ya usa acuerdo de claves poscuántico;
 - solo alrededor del 3.7 % de los servidores de origen lo soporta;
 - las firmas y los certificados van más atrasados.

- **Datos de la demo.** Una firma ML-DSA-65 mide 3309 bytes, unas 50 veces más que una firma Ed25519 (64 bytes, tamaño estándar de referencia; la demo no ejecuta Ed25519). La clave pública mide 1952 bytes frente a 32. Esta medición explica por qué autenticar es más costoso que establecer claves: una cadena TLS transporta varias firmas y claves públicas.
- **Riesgos (tríada CID).**
 - Confidencialidad: *store now, decrypt later*.
 - Integridad y autenticidad: firmas que deben migrar a ML-DSA o SLH-DSA.
 - Disponibilidad: el incidente del 10 de junio de 2026, cuando un cambio en la validación de certificados durante la actualización de BoringSSL invalidó certificados de clientes.

IN5. Elabora conclusiones a partir de la síntesis y análisis de los resultados de la investigación

Texto literal del indicador

Elabora conclusiones a partir de la síntesis y análisis de los resultados de la investigación.

Respuesta del grupo

Las conclusiones (Sección VI del informe) se derivan de IN1–IN4.

1. **El riesgo ya existe (IN1).** Por *store now, decrypt later*, la amenaza cuántica es un riesgo presente para la confidencialidad de datos de larga vida.
2. **Los estándares están listos; la migración no (IN3, IN4).** ML-KEM, ML-DSA y SLH-DSA están estandarizados y el acuerdo de claves híbrido ya protege más de la mitad del tráfico humano de Cloudflare. En cambio, las firmas, los certificados y los servidores de origen van rezagados. La demo confirma una de las causas: el tamaño de las firmas.
3. **El reto es de ingeniería y gestión, no de algoritmos (IN4).** Una organización preparada conoce sus dependencias criptográficas y puede cambiarlas sin romper la interoperabilidad ni la disponibilidad. Por eso el inventario criptográfico y la cripto-agilidad son la primera defensa.
4. **Vacíos.** La academia necesita una definición y una métrica comunes de cripto-agilidad. La industria necesita criterios verificables de preparación.
5. **Impacto actual y tendencia.** En 2026 la PQC avanza de la confidencialidad hacia la autenticación y más allá de la Web: IPsec poscuántico con equipos Fortinet y Cisco, y autenticación ML-DSA hacia servidores de origen. El incidente del 10 de junio muestra que la próxima dificultad será mantener la disponibilidad durante estos cambios.
6. **Qué debería vigilar un profesional de seguridad:**
 - la llegada de certificados poscuánticos a las PKI públicas;
 - las hojas de ruta PQC de sus proveedores;
 - la protección de la negociación híbrida contra *downgrade*;
 - el inventario criptográfico de su propia organización.

Límites de lo que se puede afirmar: el trabajo se basa en cinco fuentes principales, la evidencia de despliegue proviene de un solo proveedor y la demo mide tamaños, no rendimiento en red. Por eso no se generaliza el grado de adopción a otros sectores ni se cuantifica el impacto en latencia.